Logging, Monitoring and Audit Policy

Document ID	SEC-015
Department	IT and Information Security
Document type	Policy
Owner	GRC Manager
Version	3.0
Status	APPROVED
Effective / last reviewed	2025-09-13
Audience	All employees and contractors
Related documents	ENG-010, SEC-002, SEC-010

Summary. Policy defining what Northstar Systems logs, how long logs are kept (security audit logs 24 months), how time is synchronised, weekly log review, privileged action logging, permitted employee monitoring, and the internal and external audit programme with remediation timelines.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This policy defines how Northstar Systems Private Limited ("Northstar") records security-relevant events, reviews those records, monitors systems and staff activity in a lawful and proportionate way, and audits compliance with its security policies. It supports investigations, incident response, accountability and external assurance. The policy applies to all corporate IT systems, production systems, cloud accounts, endpoints, network devices and applications operated by or for Northstar, and to all employees, contractors and vendors who use them.

Log collection, search, alerting and the security information and event management (SIEM) function are provided by NorthWatch. Operational observability (metrics, traces, dashboards) is covered in the Observability and Monitoring Standard (ENG-010); this policy concentrates on security and audit logging. References to external frameworks or laws are illustrative and must be verified by Legal before external use.

2. Definitions

- **Security audit log:** a record of security-relevant events, such as logins, access changes, privileged actions, policy changes and access to Restricted data.
- **Application log:** a record produced by an application for debugging and operations.
- **Privileged action:** an action performed with elevated rights, for example by administrators, through the NorthGate bastion, through break-glass accounts or in an admin console.
- **Tamper-evident storage:** storage in which any change or deletion of a record is detectable, for example write-once or hash-chained storage.
- **Security Operations:** the team within IT/Security that monitors alerts and reviews logs.
- **Break-glass account:** an emergency account used only when normal access fails.
- **Audit finding:** a documented gap between required and actual practice, rated High, Medium or Low.

3. Roles and Responsibilities

Role	Responsibility
CISO	Approves this policy's scope and exceptions to log retention
GRC Manager	Owns the policy, plans internal and external audits, tracks findings
Security Operations	Reviews logs weekly, triages alerts in NorthWatch, investigates anomalies
System owners	Ensure their systems send required logs to NorthWatch and fix gaps
Engineering teams	Implement logging in applications according to ENG-010 and this policy
Privacy Officer	Reviews monitoring practices for proportionality (see SEC-014)
HR (People Team)	Joins investigations where staff conduct is involved
All users	Accept that monitoring takes place and must not disable or tamper with logging

4. What Must Be Logged

4.1 Mandatory security events

Every system that handles Confidential or Restricted data, and every production system, must log at least the following events with timestamp, user or service identity, source address and outcome:

- Successful and failed authentication, including MFA events in NorthID and account lockouts (5 failed attempts triggers a 15-minute lockout).
- Creation, change, disablement and deletion of accounts, roles and permissions.
- Approval and use of just-in-time privileged access.
- All privileged actions, which must always be logged. Production administration sessions through NorthGate are also recorded as sessions.
- Use of break-glass accounts.
- Access to, export of and bulk changes to Restricted data.
- Changes to security configuration, such as firewall rules, encryption settings and logging settings themselves.
- Deployments and change-ticket references from NorthShip.
- Endpoint events from NorthGuard, such as encryption status changes and disabled agents.
- VPN sessions on NorthTunnel.

4.2 What must not be logged

Logs must not contain passwords, authentication tokens, API keys, encryption keys, full payment card numbers or full government identifiers. Developers must mask or exclude such values. Personal data in logs must be minimised (see SEC-014). If a secret is found in a log, it must be treated as exposed: the owner must rotate the secret and report the finding to the Security Desk.

4.3 Log sources and owners

The following table shows the principal log sources, who owns them and what Security Operations expects to see in NorthWatch. System owners must confirm every year, during the access review in January, that their sources are still forwarding.

Source	Owner	Expected content	Forwarding check
NorthID	IT/Security	Logins, MFA results, lockouts, password and factor changes	Continuous, alert after 15 minutes of silence

Source	Owner	Expected content	Forwarding check
NorthGate bastion	Platform Engineering	Session start and end, commands, recordings index	Continuous
NorthShip	Release Engineering	Pipeline runs, approvals, deployments, rollbacks	Continuous
NorthGuard	IT/Security	Encryption status, agent health, device compliance	Daily
NorthTunnel	IT/Security	VPN sessions, source addresses, failed attempts	Continuous
Cloud control plane	Cloud Operations	Console and API actions, policy and key changes	Continuous
NorthPay and NorthPeople	HR Systems and Finance	Admin changes, exports, role changes	Daily

If a new system is introduced, its owner must complete a logging checklist with the GRC team before go-live, confirming which events are logged, where logs are sent, how long they are kept and who reviews them. A system without an approved checklist must not hold Confidential or Restricted data.

4.4 Log access requests

Engineers who need logs for debugging may search application logs in NorthWatch under their normal role. Requests for security audit logs from outside Security Operations, for example by a manager, an auditor or HR, must be raised in NorthDesk with a stated purpose and are approved by the GRC Manager. Bulk exports of logs that contain personal data need the Privacy Officer's agreement. Each request, approval and export is itself recorded, so that the use of logs can be audited in the same way as any other privileged activity.

Example: An external auditor asks for all administrator logins to the cloud control plane during the last 6 months. The GRC Manager approves a read-only export of the relevant events, with personal identifiers limited to Employee IDs, and records the export in a NorthDesk ticket. The auditor receives the file through the approved audit sharing folder.

5. Retention

Log type	Retention
Security audit logs	24 months in tamper-evident storage
Application logs	12 months (30 days hot, then archived)
Metrics	13 months
Traces	15 days
Forensic evidence for incidents	12 months
CCTV	30 days

Security audit logs must be kept for 24 months in tamper-evident storage, and no administrator may delete or edit them during that time. A legal hold overrides these periods and prevents deletion until Legal releases it. After the period ends, logs are deleted using a method that produces a destruction record. Retention periods for other record types are in SEC-005.

Example: A customer raises a dispute about a configuration change made 20 months ago. Security Operations can still retrieve the audit log for the change because security audit logs are held for 24 months. The same request about a 30-month-old event could not be answered from logs.

6. Log Protection and Time Synchronisation

- All systems must synchronise time using NTP from approved internal time sources. Clock drift of more than 1 second must be corrected, because inaccurate timestamps weaken investigations.
- Logs must be shipped to NorthWatch in near real time and stored separately from the systems that produce them, so that an attacker who controls a server cannot erase its history.
- Access to the log platform is limited to Security Operations and designated engineers on a read-only basis. Changes to log pipelines need a NorthDesk change ticket.
- Logs in transit must use TLS 1.2 or higher and logs at rest must use AES-256 encryption.
- Loss of log forwarding from a Tier-1 or security-relevant system for more than 15 minutes raises an alert, and the system owner must restore forwarding within 1 business day.

7. Monitoring and Review

7.1 Automated monitoring

NorthWatch applies detection rules for impossible travel logins, repeated failed logins, new administrator accounts, disabled logging, privileged use outside approved windows, mass downloads of Restricted data, and malware alerts from NorthGuard. High-priority alerts page the Security Operations on-call. Paging alerts must relate to real impact and must carry a runbook link.

7.2 Weekly log review

Security Operations must review logs weekly. The review covers privileged activity summaries, failed-login trends, new and changed administrator accounts, break-glass use, access to Restricted data and alert volumes. The reviewer records the outcome in a NorthDesk ticket showing what was reviewed, anomalies found and actions taken. Missed weekly reviews are reported to the CISO.

7.3 Break-glass and privileged access review

Every use of a break-glass account must be reviewed within 1 business day by the CISO's delegate, who confirms the reason, the actions taken and that the password was changed afterwards. Just-in-time privileged access to production, granted for a maximum of 8 hours, is checked against the approved NorthDesk request during the weekly review.

7.4 Quarterly access reviews

Quarterly user access reviews (January, April, July and October) use log data to identify dormant accounts. Accounts inactive for 60 days are disabled and deleted after 180 days, as set out in SEC-002.

8. Monitoring of Employees and Contractors

Northstar monitors corporate systems to protect the company, customers and staff. By using company devices and accounts, users accept the monitoring described here. Monitoring is limited to what is necessary and proportionate.

Permitted:

- Logs of authentication, network connections, web gateway categories, email metadata and security tooling alerts on company systems.
- Endpoint agent telemetry from NorthGuard, such as installed software, patch level and encryption state.
- Scanning of email and files for malware and for Restricted data leaving the company.
- Review of the content of an individual's company email, files or logs only as part of an authorised investigation.

Not permitted:

- Monitoring of personal devices, personal accounts or personal messages, except limited management data on a BYOD phone enrolled in NorthGuard for email and NorthID.
- Keystroke logging or screen capture of employees as routine practice.
- Using monitoring data for any purpose unrelated to security, compliance or an authorised investigation, such as informal performance snooping.

Access to the content of an employee's mailbox or files requires written approval from the CISO and the Chief People Officer, with the Privacy Officer informed. Security Operations staff must not browse such content out of curiosity; their own access is logged and reviewed.

Example: HR receives a complaint that a team member may have emailed a customer list to a personal address. The Chief People Officer and the CISO approve a targeted review of that user's outbound mail for the last 60 days. Security Operations delivers only the relevant records to HR and the review is recorded in a NorthDesk ticket.

9. Audit Programme

9.1 Internal audit

Internal audit of security controls is carried out annually, with scope defined by the GRC Manager and approved by the CISO. Typical scope includes access management, change control, logging, vendor assessments, incident handling and backup restore testing. Auditors need read access to evidence, which is provided through NorthDesk tickets and exports from NorthWatch.

9.2 External audit

An independent external audit is carried out annually against an ISO 27001-style framework (illustrative). Customer-requested audits are handled by the GRC Manager within contract terms and must not give auditors direct access to production systems or other customers' data.

9.3 Penetration testing and scans

Vulnerability scans run weekly and an external firm performs a penetration test annually, as described in SEC-007. Results are tracked as audit findings.

9.4 Findings and remediation

Rating	Meaning	Remediation deadline
High	Control missing or failing with significant risk	Within 60 days
Medium	Partial control or documentation gap	Within 120 days
Low	Improvement opportunity	Within the next audit cycle

High findings must be remediated within 60 days. The finding owner prepares a plan with owner, actions and dates in NorthDesk. If a deadline cannot be met, the owner must request a time-bound exception from the CISO's delegate; risk acceptance expires after a maximum of 90 days and must be renewed explicitly. The GRC Manager reports open findings monthly to the CISO and quarterly to the CEO and the Board risk committee.

10. Incident Use of Logs

During a security incident (see SEC-010), the Incident Response Lead may direct Security Operations to preserve relevant logs and widen collection. Logs related to the incident must be copied to protected storage and retained for 12 months as forensic evidence. Chain of custody is documented. Where personal data may be affected, the Privacy Officer must be told immediately.

11. Exceptions and Escalation

A system that cannot meet a logging requirement, for example a legacy appliance with no export capability, needs a documented exception. The system owner raises the request in NorthDesk with compensating controls, such as additional network monitoring. The CISO's delegate may approve it for a maximum of 90 days. Shortening of retention periods is never allowed, except where the Privacy Officer requires earlier deletion of personal data in logs and Legal confirms there is no hold. Any attempt to disable, alter or bypass logging is a serious violation and may lead to disciplinary action under the Code of Conduct.

12. Worked Scenarios

Scenario 1: engineer needs production access. A Site Reliability Engineer needs to debug a Tier-1 service. She raises an Access Request in NorthDesk; her Director and the CISO delegate approve; access is granted just-in-time for up to 8 hours, and the session passes through NorthGate with recording. Security Operations later matches the session to the request in the weekly review.

Scenario 2: logging gap on a new service. During a design review, the team of a new Tier-2 service discovers it only keeps logs for 30 days. The system owner must change retention so security audit events are shipped to NorthWatch and kept for 24 months before go-live.

Scenario 3: unexplained break-glass login. NorthWatch alerts at 02:10 IST that a break-glass account logged into the cloud console. Security Operations contacts the on-call engineer; if the use is legitimate it is documented, and the CISO delegate reviews it within 1 business day. If it is not legitimate, a Critical security incident is declared and the Security Desk is notified immediately.

13. Frequently Asked Questions

How long are audit logs kept? Security audit logs are kept for 24 months. Application logs are kept for 12 months.

Can my manager read my emails? Not on request. Access to mailbox content needs written approval from the CISO and the Chief People Officer and must be part of an authorised investigation.

Is my personal phone monitored? Only limited management data is visible on a BYOD phone enrolled for email and NorthID. Personal content is not monitored.

14. Related Documents

See ENG-010 for operational observability, SEC-002 for access management and access reviews, SEC-010 for incident response, SEC-007 for vulnerability scanning, SEC-005 for retention and SEC-014 for privacy.

15. Revision History

Version	Date	Change
2.8	2024-11-18	Added break-glass review wording
2.9	2025-04-09	Clarified employee monitoring limits
3.0	2025-09-13	Aligned retention with SEC-005 and audit timelines